

## SIMATS ENGINEERING

### ASSESSMENT TOOL 3

|                 |              |
|-----------------|--------------|
| Name            | SHAIK REEHNA |
| Register Number | 192565071    |
| Date            |              |
| Time            |              |

**COURSE NAME:** Cybersecurity Incident Handling And Response

**COURSE CODE:** CSA60

---

#### COURSE OUTCOME COVERED

**CO2:** *Analyze incident response preparation strategies through examination of team roles, policies, SOPs, risk management practices, along with compliance frameworks to ensure organizational readiness. (BL3, BL6)*

Activity Tool : Security Operations Workflow using SIEM and Ticketing System (Low)

Assessment Tool Weightage: 10%

---

---

#### **Code of Conduct:**

*I \_\_\_\_\_ Shaik reehan\_\_\_\_\_ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.*

*I understand that any violation of academic integrity rules will result in disciplinary action.*

#### **Signature of the student:**

Shaik reehan

## RUBRICS FOR CALCULATION:

| Criteria                                                       | Weightage  | Level 4 (Exemplary)                                                                                                                                                                                                                                       | Level 3 (Proficient)                                                                                             | Level 2 (Developing)                                                                                              | Level 1 (Beginning)                                                                                         |
|----------------------------------------------------------------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| <b>Security Operations Workflow Design</b>                     | <b>20%</b> | Develops a complete and logical security operations workflow from SIEM alert generation to incident closure, clearly explaining all stages including monitoring, investigation, response, recovery, and documentation.                                    | Develops a workflow covering most stages with only minor omissions or sequencing issues.                         | Describes only basic workflow steps with several missing or incomplete phases.                                    | Fails to develop a coherent security operations workflow or omits major activities.                         |
| <b>SIEM Alert Analysis and Ticket Management</b>               | <b>25%</b> | Accurately analyzes SIEM alerts, prioritizes incidents based on severity and business impact, effectively manages ticket creation, assignment, tracking, escalation, and closure using appropriate workflows.                                             | Correctly analyzes most alerts and demonstrates good understanding of ticket management with minor omissions.    | Demonstrates partial understanding of SIEM alerts and ticketing concepts with several missing or incorrect steps. | Shows little or no understanding of SIEM alert handling or ticket management processes.                     |
| <b>Escalation, SOP, and Communication Process</b>              | <b>20%</b> | Develops a comprehensive SOP with clearly defined escalation levels, communication channels, stakeholder responsibilities, and incident handling procedures throughout the response lifecycle.                                                            | Includes appropriate SOP and escalation procedures with minor gaps in communication or stakeholder coordination. | Provides limited SOP or escalation process with insufficient communication planning.                              | SOP is incomplete, inaccurate, or lacks escalation and communication procedures.                            |
| <b>Risk Assessment, Asset Criticality, BCP, and DRP</b>        | <b>20%</b> | Correctly identifies critical assets, performs comprehensive risk assessment, prioritizes incidents appropriately, and clearly explains Business Continuity Planning (BCP) and Disaster Recovery Planning (DRP) strategies with suitable recommendations. | Performs basic risk assessment and asset prioritization while explaining BCP/DRP with minor omissions.           | Performs partial risk assessment with limited understanding of asset criticality, BCP, or DRP concepts.           | Unable to identify risks, prioritize assets, or explain BCP and DRP strategies effectively.                 |
| <b>Documentation, Reporting, and Professional Presentation</b> | <b>15%</b> | Documentation is well-structured, professionally presented, includes appropriate ticket records, incident reports, workflow diagrams/tables, and communicates ideas clearly and logically.                                                                | Documentation is organized and complete with only minor formatting or clarity issues.                            | Documentation is partially organized with several missing details or presentation issues.                         | Documentation is poorly organized, incomplete, difficult to understand, or lacks professional presentation. |

# Standard Operating Procedure: Ransomware Incident Response

---

## 1. Purpose

This Standard Operating Procedure (SOP) defines the structured process the financial institution will follow to prepare for, detect, respond to, recover from, and learn from a ransomware attack. The objective is to minimize business disruption, protect customer and financial data, preserve forensic evidence, meet regulatory reporting obligations, and restore normal operations as quickly and safely as possible.

## 2. Scope

This SOP applies to all employees, contractors, and third-party service providers with access to the institution's information systems, networks, applications, and data. It covers all endpoints, servers, network devices, cloud environments, and core banking systems within the institution's IT estate.

## 3. Roles and Responsibilities

| Role                          | Responsibility                                                                                                                                            |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Incident Commander (IC)       | Overall command of the response; coordinates all teams and decision-making.                                                                               |
| SOC Analyst / CSIRT           | Monitors alerts, performs triage, investigates and executes technical response actions.                                                                   |
| IT / Infrastructure Team      | Executes containment, eradication, and recovery actions on systems and networks.                                                                          |
| Digital Forensics Team        | Collects, preserves, and analyzes evidence; maintains chain of custody.                                                                                   |
| Legal & Compliance            | Advises on regulatory notification duties (e.g., RBI/central bank, data protection authorities), contractual obligations, and law enforcement engagement. |
| Corporate Communications / PR | Manages internal and external messaging, customer communication, and media enquiries.                                                                     |
| Executive Management / CISO   | Approves major decisions (e.g., ransom stance, system shutdowns), owns regulatory sign-off.                                                               |
| Human Resources               | Supports internal communication and, where relevant, disciplinary/insider matters.                                                                        |

## 4. Preparation (Before an Incident)

Preparation activities are performed continuously, independent of any active incident, to reduce the likelihood and impact of a ransomware attack.

| Activity                           | Description                                                                                                                                   |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| Asset & data inventory             | Maintain an up-to-date inventory of critical systems, applications, and data classification (especially customer financial data).             |
| Risk assessment                    | Conduct periodic ransomware-specific risk assessments and vulnerability scans across the environment.                                         |
| Backup strategy                    | Implement the 3-2-1 backup rule with at least one immutable/offline/air-gapped copy; test restore procedures quarterly.                       |
| Endpoint & network defenses        | Deploy EDR/XDR, next-gen antivirus, email/web filtering, and network segmentation (especially isolating core banking systems).                |
| Identity & access management       | Enforce least privilege, MFA on all remote and privileged access, and regular access reviews.                                                 |
| Patch management                   | Maintain a defined SLA for patching critical vulnerabilities on internet-facing and internal systems.                                         |
| Incident Response Plan & playbooks | Maintain a documented, approved ransomware-specific playbook aligned to this SOP.                                                             |
| Team readiness                     | Maintain an up-to-date IR team contact list, on-call roster, and escalation matrix.                                                           |
| Tabletop exercises                 | Conduct ransomware simulation drills at least twice a year involving IT, Legal, Communications, and Executive teams.                          |
| Security awareness training        | Run regular phishing simulations and staff training, since phishing is the leading ransomware entry vector.                                   |
| External relationships             | Pre-establish contacts with law enforcement (e.g., CERT-In/FBI), cyber insurance provider, and external forensics/incident response retainer. |

## 5. Identification (Detection & Analysis)

| Activity              | Description                                                                                                                                               |
|-----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Alert triage          | SOC analysts triage SIEM/EDR alerts indicating ransomware behavior (mass file encryption, suspicious process execution, abnormal file-extension changes). |
| Validate the incident | Confirm indicators of compromise (IOCs): ransom notes, encrypted file extensions, unusual outbound traffic to command-and-control (C2) infrastructure.    |

| Activity                | Description                                                                                                                  |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------|
| Determine scope         | Identify affected systems, accounts, network segments, and the ransomware variant/family involved.                           |
| Severity classification | Classify incident severity (Critical/High/Medium/Low) based on systems affected and business impact, per the IR plan matrix. |
| Activate the CSIRT      | Formally declare the incident and activate the Incident Commander and Cyber Security Incident Response Team (CSIRT).         |
| Initial notification    | Notify the CISO, SOC Manager, and Executive Management within the defined SLA (e.g., 30 minutes of confirmation).            |

## 6. Containment

### 6.1 Short-term containment

- Isolate infected endpoints/servers from the network (disconnect network cable / disable Wi-Fi / switch off via VLAN quarantine).
- Disable or suspend compromised user and service accounts.
- Block identified malicious IPs, domains, and C2 infrastructure at firewall/proxy level.
- Disable remote access services (RDP, VPN) where compromise is suspected.
- Preserve volatile data (RAM, running processes, network connections) before powering down systems, wherever feasible.

### 6.2 Long-term containment

- Apply additional network segmentation to prevent lateral movement to core banking and payment systems.
- Deploy temporary compensating controls (enhanced monitoring, additional MFA) on unaffected critical systems.
- Rotate credentials and certificates for all privileged and service accounts in the affected domain.

## 7. Eradication

- Identify and remove the ransomware payload, persistence mechanisms (scheduled tasks, registry keys, malicious services), and any backdoors.
- Identify and remediate the root-cause vulnerability or attack vector (e.g., unpatched CVE, phishing-compromised credential, exposed RDP).
- Rebuild severely compromised systems from known-good, verified images rather than attempting in-place cleaning.
- Run full environment scans (EDR/AV) to confirm no residual malicious artifacts remain.
- Reset all potentially compromised credentials, including Active Directory/domain admin accounts and API keys.

## 8. Recovery

- Validate backup integrity and confirm backups are free of malware before restoration.
- Restore systems in a prioritized, phased order — critical business and customer-facing banking systems first, per the Business Impact Analysis.
- Restore in an isolated/segmented environment initially, with enhanced monitoring, before reconnecting to production network.
- Perform functional and data-integrity testing before declaring systems operational.
- Obtain formal sign-off from system owners, IT leadership, and the Incident Commander before returning systems to normal production.
- Continue heightened monitoring (e.g., 30–90 days) for signs of reinfection or residual attacker access.

## 9. Evidence Collection

- Create forensic disk/memory images of affected systems prior to remediation, using write-blocking tools.
- Preserve and export relevant logs: SIEM, EDR, firewall, VPN, Active Directory, email gateway, and application logs.
- Capture the ransom note, malware sample(s), and any attacker communication (in a secure, isolated analysis environment).
- Maintain a strict chain-of-custody log for every piece of evidence collected (who, what, when, where, hash values).
- Engage external digital forensics specialists and, where required, coordinate evidence handover with law enforcement.

## 10. Documentation

- Maintain a detailed, timestamped incident timeline from detection through closure.
- Record all response actions taken, by whom, and the outcome of each action.
- Document systems, applications, and data affected, including any confirmed data exfiltration.
- Log all internal and external communications, including regulatory notifications and customer disclosures.
- Complete required regulatory notifications (e.g., central bank/financial regulator, data protection authority) within statutory timeframes.
- Prepare a final incident report summarizing root cause, impact, response actions, and cost/impact assessment.

## 11. Lessons Learned (After the Incident)

- Conduct a formal post-incident review meeting within 1–2 weeks of incident closure, including all stakeholder teams.
- Perform root-cause analysis and identify control gaps that allowed the attack to succeed.
- Update the Incident Response Plan, playbooks, and this SOP based on findings.
- Assign, track, and close remediation action items with clear owners and deadlines.

- Update security awareness training and technical controls based on the attack vector identified.
- Share sanitized findings with relevant industry information-sharing bodies (e.g., financial sector ISAC) where appropriate.

# Security Operations Center (SOC) Dashboard Design

---

## 1. Objective

The SOC dashboard provides the SOC manager and analysts with real-time, at-a-glance visibility into the institution's security posture, incidents detected by the SIEM, and the operational performance of the SOC team. It consolidates data from the SIEM, EDR, firewalls, and ticketing/SOAR systems into a single visual interface to support fast, informed decision-making.

## 2. Key Performance Indicators (KPIs)

| KPI                            | Description                                                                                     |
|--------------------------------|-------------------------------------------------------------------------------------------------|
| Mean Time to Detect (MTTD)     | Average time between an attacker's initial activity and detection by the SOC.                   |
| Mean Time to Respond (MTTR)    | Average time between alert triage and the first responsive action.                              |
| Mean Time to Contain (MTTC)    | Average time from detection to full containment of an incident.                                 |
| Mean Time to Resolve           | Average time from detection to full incident closure.                                           |
| SLA Compliance Rate            | Percentage of alerts/incidents triaged and resolved within defined SLA thresholds.              |
| False Positive Rate            | Proportion of alerts that were closed as non-incidents, used to tune detection rules.           |
| Alert-to-Incident Ratio        | Number of raw alerts vs. number confirmed as true incidents, indicating detection efficiency.   |
| Analyst Workload               | Number of open cases per analyst / average handling time, for capacity planning.                |
| Patch/Vulnerability Compliance | Percentage of critical assets patched within policy SLA.                                        |
| Backup Success Rate            | Percentage of scheduled backup jobs completed successfully, critical for ransomware resilience. |

## 3. Security Metrics

- Alert volume trend by source (SIEM, EDR, firewall, email gateway, cloud) over time.
- Top targeted/attacked assets and business units.
- Top source IPs/countries generating malicious traffic (geo-map view).



- Malware/ransomware detections and blocked count.
- Phishing emails reported and blocked.
- Open vulnerabilities by severity (Critical/High/Medium/Low) and aging.
- Endpoint protection and agent health/coverage percentage.
- Privileged account activity and anomalous login attempts.

## 4. Alert / Incident Categories

| Category                      | Examples                                                              |
|-------------------------------|-----------------------------------------------------------------------|
| Malware / Ransomware          | Ransomware encryption activity, trojans, worms.                       |
| Phishing / Social Engineering | Credential harvesting emails, business email compromise.              |
| Unauthorized Access           | Brute force attempts, impossible-travel logins, privilege escalation. |
| Data Exfiltration             | Abnormal outbound data transfer, unauthorized cloud uploads.          |
| Denial of Service             | Volumetric or application-layer DDoS attempts.                        |
| Insider Threat                | Policy violations, unusual access by internal users.                  |
| Vulnerability Exploitation    | Exploitation attempts against known CVEs.                             |
| Policy / Compliance Violation | Unauthorized software, configuration drift, DLP violations.           |

## 5. Incident Status Indicators

Incidents are color-coded by status for immediate visual recognition:

- New — Red: newly generated, not yet triaged.
- In Progress — Orange: under active investigation by an analyst.
- Contained — Yellow: threat isolated, eradication/recovery underway.
- Resolved / Closed — Green: incident fully remediated and closed.
- False Positive — Grey: alert reviewed and closed as non-incident.

Severity levels (Critical / High / Medium / Low) are layered alongside status to help the SOC manager prioritize resource allocation at a glance.

## 6. Reporting Features

| Feature               | Purpose                                                                                                            |
|-----------------------|--------------------------------------------------------------------------------------------------------------------|
| Real-time widgets     | Live counters for open incidents, active alerts, and SLA breaches, refreshed continuously from the SIEM/SOAR feed. |
| Drill-down capability | Click-through from a summary chart into the underlying incident tickets and raw log evidence.                      |

| Feature                       | Purpose                                                                                                   |
|-------------------------------|-----------------------------------------------------------------------------------------------------------|
| Executive summary view        | A simplified, high-level view for CISO/leadership showing risk posture, trend, and major incidents.       |
| Analyst working view          | Detailed operational queue view with case assignment, priority, and SLA timers.                           |
| Trend & heat-map analysis     | Visualizes attack trends over time and identifies hot-spot assets/business units.                         |
| Scheduled & on-demand reports | Automated daily/weekly/monthly reports emailed to stakeholders; exportable to PDF/Excel.                  |
| Compliance reporting          | Pre-built views aligned to regulatory requirements (e.g., central bank cyber-security reporting formats). |
| SOAR/ticketing integration    | Two-way sync with the case management system so dashboard status always reflects ticket status.           |

## 7. How the Dashboard Supports Decision-Making

By consolidating KPIs, live alert feeds, and status indicators into a single view, the dashboard allows the SOC manager to quickly identify where attention and resources are most needed — for example, spotting an SLA breach in progress or an unusual spike in ransomware-pattern alerts before it becomes a full-blown incident. Trend and heat-map views support proactive, risk-based decisions such as prioritizing patching or reallocating analyst coverage to a targeted business unit. Executive-level views give senior management the risk visibility needed to approve budget, staffing, or policy changes, while compliance reporting features ensure the institution can demonstrate due diligence to regulators. In short, the dashboard turns raw SIEM data into timely, actionable intelligence that shortens detection and response times and strengthens the institution's overall cyber-resilience.